

Security posture report

Comprehensive risk posture & audit summary

Generated 2026-07-05 12:54 UTC

Generated by Analyst Yote (Analyst)

Scope: 27 findings - 3 frameworks - 125 controls

Point-in-time snapshot of live data

86 / 100

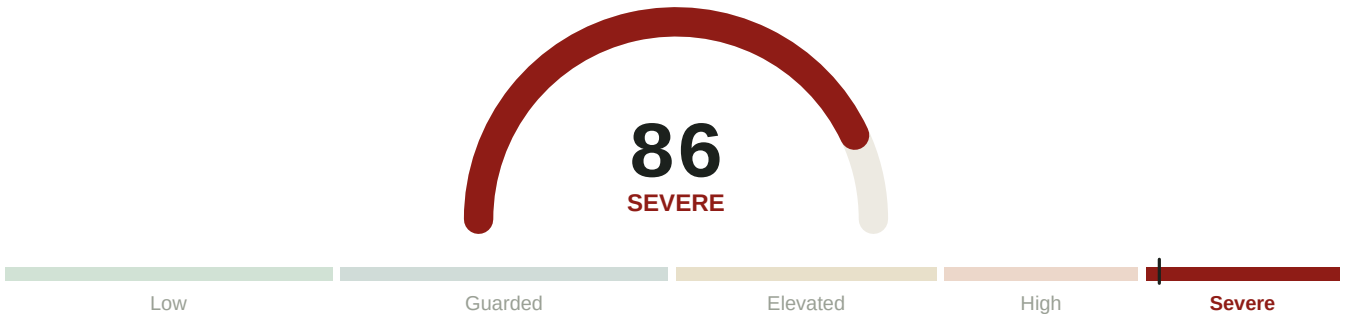
SEVERE

Overall risk posture (0-100, higher = worse).

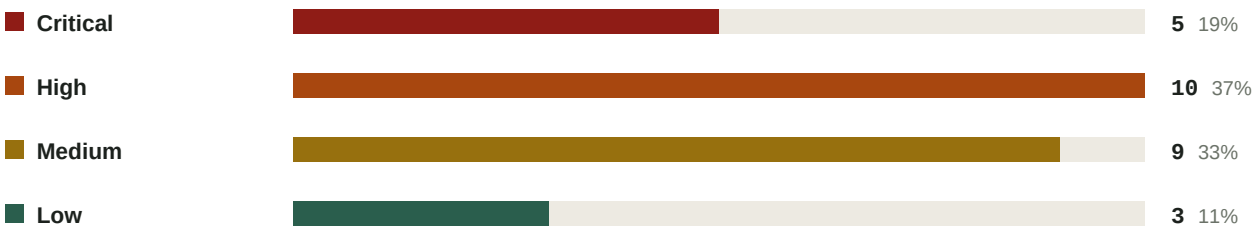
Derived from all active findings - see Methodology.

TOTAL FINDINGS 27 All recorded (excl. deleted)	ACTIVE FINDINGS 16 Not yet resolved or closed	CRITICAL ACTIVE 4 Highest-weight exposure	REMIEDIATED (90D) 4 Closed in the last 90 days
---	--	--	---

Overall risk posture

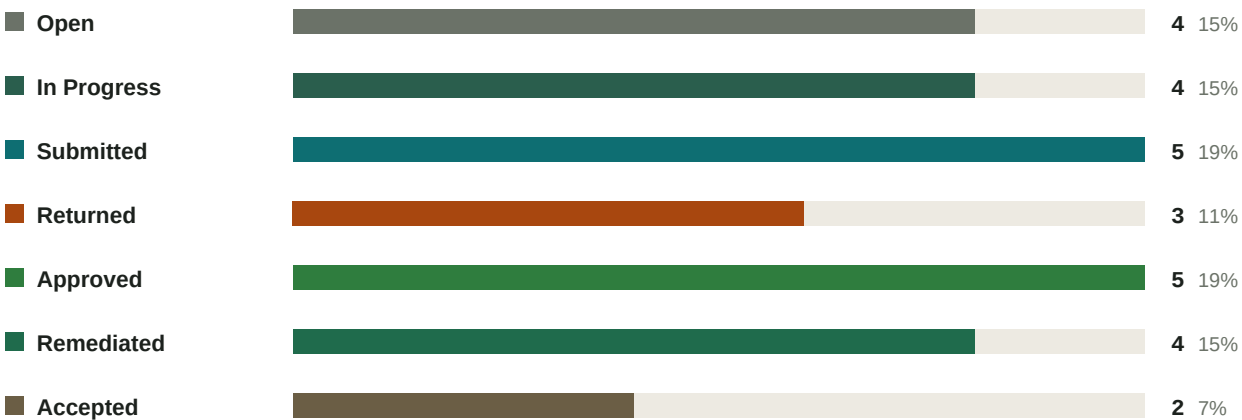


Findings by severity



All recorded findings, excluding deleted.

Findings by workflow status



Workflow order; approved/remediated/accepted no longer add to the posture load.

Risk concentration - severity × status

	Open	In Progress	Submitted	Returned	Approved	Remediated	Accepted
Critical	2	1	1	-	-	1	-
High	1	-	2	1	4	1	1
Medium	1	3	1	2	-	2	-
Low	-	-	1	-	1	-	1

Cell colour = inherent risk (severity × workflow state), independent of count.

Lower  Higher

Key insights

- 16 of 27 findings are active; critical findings carry the largest share of the posture load (40 of 86 weighted points, 47%).
- Active risk is spread across 16 findings (the top 3 carry 27%) - broad remediation effort is needed.
- 5 findings await reviewer decision in the review queue.
- 3 findings were returned by review and need analyst rework.
- The longest-open high/critical finding (CM-2025-0481) has been active for 6 days.
- 2 risks formally accepted, including 1 high/critical - exposure retained by explicit decision (see Risk acceptances).
- ISO/IEC 27001 2022 has the lowest control coverage (14% - 80 controls with no mapped findings; unmapped controls are either unaffected or not yet assessed).
- 12 controls across all frameworks are currently at risk (mapped to at least one active high/critical finding).

Recommended actions

1. Remediate the 4 active critical findings first - critical findings carry the largest posture weight.
2. Clear the review queue: 5 submitted findings await a reviewer decision.
3. Rework and resubmit the 3 returned findings.
4. Re-validate the 1 accepted high/critical risk - confirm the acceptance rationale still holds.
5. Assess the 80 unmapped controls in ISO/IEC 27001 2022 to close assessment gaps.

Derived automatically from the data in this report by fixed rules - no manual editing, no generative AI. Point-in-time snapshot: no score history exists yet, so statements describe the present state only, never a trend.

Top risks - highest-scoring active findings

Top 10 of 16 active findings by effective risk score (CVSS when recorded, otherwise severity-derived - marked "der").

Reference	Title	Severity	Risk	Status	Owner	Age (days)
CM-2026-0010	Outdated Log4j dependency (CVE-2021-44228)	Critical	10.0	Submitted	Analyst Yote	0
CM-2025-0481	Stored XSS in customer statements export	Critical	9.8	In progress	Analyst Yote	6
CM-2025-0472	SQL injection in legacy reporting module	Critical	9.4	Open	Analyst Yote	6
CM-2025-0479	Hardcoded API credentials in payments service	Critical	9.1	Open	Analyst Yote	6

Reference	Title	Severity	Risk	Status	Owner	Age (days)
CM-2025-0468	Missing MFA on internal admin console	High	8.2	Submitted	Analyst Yote	6
CM-2025-0461	Unrestricted file upload type on document intake	High	7.7	Open	Analyst Yote	6
CM-2026-0007	Stored XSS in comment field	High	7.4	Submitted	Tom Becker	0
CM-2026-0018	Unencrypted PII at rest in the analytics store	High	7.1	Returned	Priya Sharma	0
CM-2026-0011	IDOR on document download	Medium	6.5	Returned	Nadia Rahman	0
CM-2025-0449	CSRF on customer profile update	Medium	6.1	Returned	Analyst Yote	6

Risk acceptances & review activity

Review activity, last 90 days: 8 approved - 7 returned - 5 currently awaiting review. Accepted risks below remain live exposure.

Reference	Title	Severity	Risk	Accepted by	Accepted on
CM-2026-0016	Insecure deserialization in report import	High	8.8	Sofia Marino	2026-07-04
CM-2025-0420	Insufficient logging in transaction service	Low	3.4	-	-

Control coverage by framework

Covered = at least one finding mapped. At risk = an active high/critical finding is mapped.

Framework	Controls	Covered	Coverage	At risk	Gaps
ISO/IEC 27001 2022	93	13	14%	6	80
NIST CSF 2.0	22	4	18%	2	18
OWASP Top 10 2025	10	10	100%	4	0

At-risk controls

Controls mapped to at least one active high or critical finding - remediation priority.

Framework	Code	Control	Findings	Highest severity
ISO/IEC 27001	A.5.17	Authentication information	3	Critical
ISO/IEC 27001	A.5.34	Privacy and protection of personal identifiable information (PII)	1	High
ISO/IEC 27001	A.8.5	Secure authentication	5	High
ISO/IEC 27001	A.8.8	Management of technical vulnerabilities	1	Critical
ISO/IEC 27001	A.8.24	Use of cryptography	4	Critical
ISO/IEC 27001	A.8.28	Secure coding	4	Critical
NIST CSF	PR.AA	Identity management, authentication & access control	3	High
NIST CSF	PR.DS	Data security	2	High
OWASP Top 10	A02	Cryptographic failures	2	High

Framework	Code	Control	Findings	Highest severity
OWASP Top 10	A03	Injection	3	Critical
OWASP Top 10	A04	Insecure design	1	High
OWASP Top 10	A06	Vulnerable & outdated components	1	Critical

Coverage gaps - controls with no mapped findings

A gap means no findings are mapped: the control is either genuinely unaffected or not yet assessed. A gap is NOT a compliance claim.

Framework	Code	Control
ISO/IEC 27001	A.5.1	Policies for information security
ISO/IEC 27001	A.5.2	Information security roles and responsibilities
ISO/IEC 27001	A.5.3	Segregation of duties
ISO/IEC 27001	A.5.4	Management responsibilities
ISO/IEC 27001	A.5.5	Contact with authorities
ISO/IEC 27001	A.5.6	Contact with special interest groups
ISO/IEC 27001	A.5.7	Threat intelligence
ISO/IEC 27001	A.5.8	Information security in project management
ISO/IEC 27001	A.5.9	Inventory of information and other associated assets
ISO/IEC 27001	A.5.10	Acceptable use of information and other associated assets
ISO/IEC 27001	A.5.11	Return of assets
ISO/IEC 27001	A.5.12	Classification of information
ISO/IEC 27001	A.5.13	Labelling of information
ISO/IEC 27001	A.5.14	Information transfer
ISO/IEC 27001	A.5.16	Identity management
ISO/IEC 27001	A.5.18	Access rights
ISO/IEC 27001	A.5.19	Information security in supplier relationships
ISO/IEC 27001	A.5.20	Addressing information security within supplier agreements
ISO/IEC 27001	A.5.21	Managing information security in the ICT supply chain
ISO/IEC 27001	A.5.22	Monitoring, review and change management of supplier services
ISO/IEC 27001	A.5.23	Information security for cloud services
ISO/IEC 27001	A.5.24	Information security incident management planning and preparation
ISO/IEC 27001	A.5.25	Assessment and decision on information security events
ISO/IEC 27001	A.5.26	Response to information security incidents
ISO/IEC 27001	A.5.27	Learning from information security incidents
ISO/IEC 27001	A.5.28	Collection of evidence
ISO/IEC 27001	A.5.29	Information security during disruption
ISO/IEC 27001	A.5.30	ICT readiness for business continuity
ISO/IEC 27001	A.5.31	Legal, statutory, regulatory and contractual requirements

Framework	Code	Control
ISO/IEC 27001	A.5.32	Intellectual property rights
ISO/IEC 27001	A.5.33	Protection of records
ISO/IEC 27001	A.5.35	Independent review of information security
ISO/IEC 27001	A.5.36	Compliance with policies, rules and standards for information security
ISO/IEC 27001	A.5.37	Documented operating procedures
ISO/IEC 27001	A.6.1	Screening
ISO/IEC 27001	A.6.2	Terms and conditions of employment
ISO/IEC 27001	A.6.3	Information security awareness & training
ISO/IEC 27001	A.6.4	Disciplinary process
ISO/IEC 27001	A.6.5	Responsibilities after termination or change of employment
ISO/IEC 27001	A.6.6	Confidentiality or non-disclosure agreements
ISO/IEC 27001	A.6.7	Remote working
ISO/IEC 27001	A.6.8	Information security event reporting
ISO/IEC 27001	A.7.1	Physical security perimeters
ISO/IEC 27001	A.7.2	Physical entry
ISO/IEC 27001	A.7.3	Securing offices, rooms and facilities
ISO/IEC 27001	A.7.4	Physical security monitoring
ISO/IEC 27001	A.7.5	Protecting against physical and environmental threats
ISO/IEC 27001	A.7.6	Working in secure areas
ISO/IEC 27001	A.7.7	Clear desk and clear screen
ISO/IEC 27001	A.7.8	Equipment siting and protection
ISO/IEC 27001	A.7.9	Security of assets off-premises
ISO/IEC 27001	A.7.10	Storage media
ISO/IEC 27001	A.7.11	Supporting utilities
ISO/IEC 27001	A.7.12	Cabling security
ISO/IEC 27001	A.7.13	Equipment maintenance
ISO/IEC 27001	A.7.14	Secure disposal or re-use of equipment
ISO/IEC 27001	A.8.1	User endpoint devices
ISO/IEC 27001	A.8.2	Privileged access rights
ISO/IEC 27001	A.8.4	Access to source code
ISO/IEC 27001	A.8.6	Capacity management
ISO/IEC 27001	A.8.7	Protection against malware
ISO/IEC 27001	A.8.10	Information deletion
ISO/IEC 27001	A.8.11	Data masking
ISO/IEC 27001	A.8.12	Data leakage prevention
ISO/IEC 27001	A.8.13	Information backup
ISO/IEC 27001	A.8.14	Redundancy of information processing facilities

Framework	Code	Control
ISO/IEC 27001	A.8.17	Clock synchronization
ISO/IEC 27001	A.8.18	Use of privileged utility programs
ISO/IEC 27001	A.8.19	Installation of software on operational systems
ISO/IEC 27001	A.8.20	Networks security
ISO/IEC 27001	A.8.21	Security of network services
ISO/IEC 27001	A.8.22	Segregation of networks
ISO/IEC 27001	A.8.23	Web filtering
ISO/IEC 27001	A.8.27	Secure system architecture and engineering principles
ISO/IEC 27001	A.8.29	Security testing in development and acceptance
ISO/IEC 27001	A.8.30	Outsourced development
ISO/IEC 27001	A.8.31	Separation of development, test and production environments
ISO/IEC 27001	A.8.32	Change management
ISO/IEC 27001	A.8.33	Test information
ISO/IEC 27001	A.8.34	Protection of information systems during audit testing
NIST CSF	GV.OC	Organizational context
NIST CSF	GV.OV	Oversight
NIST CSF	GV.PO	Policy
NIST CSF	GV.RM	Risk management strategy
NIST CSF	GV.RR	Roles, responsibilities and authorities
NIST CSF	GV.SC	Cybersecurity supply chain risk management
NIST CSF	ID.AM	Asset management
NIST CSF	ID.IM	Improvement
NIST CSF	ID.RA	Risk assessment
NIST CSF	PR.AT	Awareness and training
NIST CSF	PR.IR	Technology infrastructure resilience
NIST CSF	PR.PS	Platform security
NIST CSF	RC.CO	Incident recovery communication
NIST CSF	RC.RP	Incident recovery plan execution
NIST CSF	RS.AN	Incident analysis
NIST CSF	RS.CO	Incident response reporting and communication
NIST CSF	RS.MA	Incident management
NIST CSF	RS.MI	Incident mitigation

Methodology & definitions

Posture score: a volume-sensitive weighted sum over active findings - Critical 10, High 6, Medium 3, Low 1 - normalised against a cap of 100 weighted points, scaled to 0-100 and clamped. Higher is worse.

Active findings: status Open, In progress, Submitted or Returned. Approved, Remediated and Accepted findings no longer add to the posture load.

Effective risk score per finding: the CVSS base score when recorded, otherwise derived from severity (Critical 9.0, High 7.5, Medium 5.0, Low 2.0) - derived scores are marked "der" in the tables.

Severity bands follow CVSS v3.x: Critical 9.0-10.0, High 7.0-8.9, Medium 4.0-6.9, Low 0.1-3.9.

At-risk control: at least one active high or critical finding is mapped to it. Coverage gap: no findings mapped - the control is either unaffected or not yet assessed.

Remediated (90 days): findings in status Remediated whose last update falls inside the window.

This report is generated from live data at the timestamp on the cover. The per-finding audit trail (every status change, edit and mapping, including deleted findings) is available as the separate audit log export.